

MODULE 01 · DOMAIN 1 - DESIGN SECURE ARCHITECTURES

Identity, Policies and Cross-Account Access

Who can do what, to which resource, under what conditions.

DOMAIN 1 of 4 EXAM WEIGHT 30% MODULE 1 of 22

A role is not a stronger user. A role is a set of permissions that anything can **temporarily become**.

The identities you can grant permissions to

- ◆ **Root user.** Created with the account. Use it to set up billing and then lock it away with MFA.
- ◆ **IAM user.** A permanent identity with a password or long-lived access keys.
- ◆ **IAM group.** A container for users. Groups hold policies. Groups cannot be nested and cannot be a principal.
- ◆ **IAM role.** Permissions with no permanent credentials, assumed temporarily via STS.
- ◆ **Federated identity.** An external directory or identity provider, mapped to a role on entry.

ON THE EXAM

A group is never the answer to 'how does this application get access'. Only roles are.

User or role?

IAM USER WHEN

A human needs a permanent login

- A person signs in to the console directly
- There is no external identity provider available
- Small organisation, few people, no directory
- Credentials are rotated on a schedule

IAM ROLE WHEN

Anything else, essentially

- An EC2 instance or Lambda function needs access
- An application running anywhere needs access
- Another AWS account needs access
- A workforce signs in through a directory

THE TIEBREAKER

If the question mentions credentials stored in code, config, or environment variables, the answer is a role.

How a request is evaluated

01

Explicit deny?

Any deny anywhere wins immediately. Nothing overrides it.

02

SCP allows?

Organizations guardrails. If they do not permit it, it stops here.

03

Resource policy?

An allow here can be sufficient on its own within an account.

04

Boundary and session?

Permissions boundaries and session policies cap the maximum.

05

Identity policy allows?

If nothing has allowed it by now, the implicit deny applies.

ON THE EXAM

Deny beats allow. Allow beats nothing. There is no 'mostly allowed'.

The five policy types

POLICY TYPE	WHAT IT DOES	TYPICAL EXAM SIGNAL
Identity-based	Attached to a user, group or role	Standard 'what can this role do'
Resource-based	Attached to the resource	Cross-account without a role
Service control policy	Org guardrail. Limits, never grants	'Prevent any account from...'
Permissions boundary	Caps what a principal can have	Safe delegation of IAM
Session policy	Passed at assume-role time	Temporary scoped-down access

ON THE EXAM

Only identity-based and resource-based policies grant. The other three only subtract.

Cross-account access: the two routes

ASSUME A ROLE

Account B trusts account A

- Role in B has a trust policy naming A
- Principal in A gets temporary credentials
- Works for every service
- Access is logged as the assumed role

RESOURCE-BASED POLICY

The resource names the outside principal

- Bucket policy or queue policy names account A
- No role assumption, no credential swap
- Only services that support them
- Principal keeps its own identity

THE TIEBREAKER

Only some services support resource-based policies. Roles always work, so they are the safe default answer.

Managing identity at scale

Where the exam expects Organizations and Identity Center rather than IAM users.

- ◆ **AWS Organizations.** Groups accounts into OUs, consolidates billing, applies SCPs. The container for everything else.
- ◆ **IAM Identity Center.** One sign-in across every account. Replaces per-account IAM users entirely.
- ◆ **AWS Control Tower.** Sets up a multi-account landing zone with guardrails already configured.
- ◆ **AWS RAM.** Shares specific resources, such as subnets or Transit Gateways, across accounts.
- ◆ **Anti-pattern.** Creating the same IAM user in every account and keeping the passwords in step.

ON THE EXAM

'Hundreds of users, dozens of accounts, one sign-in' is always IAM Identity Center.

Small facts the exam actually asks about

- ◆ **Roles for services.** EC2 uses an instance profile. Lambda uses an execution role. ECS tasks use a task role.
- ◆ **STS is regional but tokens are global.** AssumeRole returns credentials with a configurable duration, up to twelve hours.
- ◆ **Policy conditions** such as source IP, MFA present, or requested region are how 'only from the office' is enforced.
- ◆ **IAM Access Analyzer** finds resources shared outside your account or organisation.
- ◆ **IAM is global.** Users, roles and policies are not region-scoped.

ON THE EXAM

'Restrict access unless MFA was used' is a condition key, not a separate service.

Grant the **minimum** permission that makes the task possible, for the **shortest** time it is needed.

An application runs on a fleet of EC2 instances behind a load balancer. It reads and writes objects in a single S3 bucket.

During a security review, an auditor finds AWS access keys written into a configuration file that is baked into the machine image. The keys belong to an IAM user with the AdministratorAccess policy attached. The team says rotating them would mean rebuilding and redeploying every image.

What should the solutions architect recommend?

- ☐ A Move the access keys into AWS Secrets Manager and have the application fetch them at start-up
- ☐ B Create an IAM role granting access to that bucket, attach it to the instances, and remove the keys
- ☐ C Replace the user's policy with a narrower one and rotate the keys every thirty days
- ☐ D Encrypt the configuration file with AWS KMS and grant the instances permission to decrypt it

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 Keys into Secrets Manager
Better than a config file, but the long-lived key still exists and still has to be rotated. Solves storage, not the underlying problem.
- B

 IAM role on the instances
Removes the long-lived credential entirely. Temporary credentials are delivered and rotated automatically, and the permission narrows to one bucket.
- C

 Narrow the policy, rotate keys
Improves least privilege but keeps a permanent key in an image, and thirty-day manual rotation is exactly the operational burden the role removes.
- D

 Encrypt the config file
Circular. The instance needs a credential to call KMS, so you have moved the problem rather than solved it.

THE SIGNAL

Long-lived keys on an EC2 instance. The fix is always a role, never better storage for the key.

A company has forty AWS accounts under AWS Organizations. Compliance requires that no account can ever create resources outside the eu-west-1 and eu-west-2 Regions.

Several accounts have their own administrators who can create IAM policies. The security team must be certain the restriction cannot be undone locally, and wants to avoid managing forty separate policy sets.

Which approach meets the requirement?

- ☐ A Attach an IAM policy denying other Regions to every user and role in each account
- ☐ B Apply a service control policy at the organisation root denying actions outside those Regions
- ☐ C Use AWS Config rules in each account to detect and delete out-of-Region resources
- ☐ D Set a permissions boundary on every role restricting the Regions it can use

◆ PAUSE AND DECIDE

Which approach meets the requirement?

- A

 IAM policy on every principal
A local administrator can detach or override it, and you are now maintaining policies in forty accounts.
- B

 SCP at the organisation root
Applies above account administrators, so it cannot be undone locally, and it is managed in one place.
- C

 Config rules that remediate
Detective, not preventive. The resource exists before it is removed, which does not meet 'can never create'.
- D

 Permissions boundaries
Correct mechanism, wrong scope. Still set per role inside each account, so a local admin can change them.

THE SIGNAL

'Cannot be overridden by account administrators' is the phrase that means service control policy.

A data analytics company in account A must let an external auditing firm, which uses its own AWS account B, read objects from one S3 bucket for the duration of a quarterly audit.

The auditors already have their own IAM identities. The security team wants access to end automatically and does not want to create or manage any identities for the auditors.

What is the MOST appropriate solution?

- ☐ A Create IAM users in account A for each auditor and send them access keys
- ☐ B Make the bucket public and share the object URLs with the auditing firm
- ☐ C Create a role in account A trusting account B, and have the auditors assume it
- ☐ D Generate presigned URLs for every object and email them to the auditors

◆ PAUSE AND DECIDE

What is the MOST appropriate solution?

- A

 IAM users for each auditor
Exactly what the question rules out. Creates identities to manage, and long-lived keys leave the organisation.
- B

 Make the bucket public
Exposes audit data to the entire internet. Never correct on this exam.
- C

 Cross-account role assumption
Auditors keep their own identities, credentials are temporary and expire, and deleting the role ends access instantly.
- D

 Presigned URLs per object
Would work for a handful of objects, but does not scale to a bucket and requires regeneration as URLs expire.

THE SIGNAL

External party with their own AWS account plus temporary access equals a cross-account role.

A development team needs to create IAM roles for the Lambda functions they build, so that they are not blocked waiting on the central security team.

Security is willing to delegate this, but must guarantee that a developer cannot create a role with more permissions than the developer already holds, and cannot grant themselves administrator rights.

Which IAM feature meets this requirement?

- ☐ A A service control policy applied to the development account
- ☐ B A permissions boundary attached to the developers' own roles
- ☐ C A session policy passed when developers assume their role
- ☐ D An IAM group containing all developers with a restrictive policy

◆ PAUSE AND DECIDE

Which IAM feature meets this requirement?

- A

 Service control policy
Caps the whole account, including the security team. It cannot express 'no more than the creator already has'.
- B

 Permissions boundary
Built for exactly this. It caps the maximum permissions of any role the developer creates, making safe delegation of IAM possible.
- C

 Session policy
Narrows one session at a time. It does not constrain roles the developer creates for other things to use later.
- D

 IAM group with a policy
Controls what developers can do, not what the roles they create are allowed to do.

THE SIGNAL

'Delegate IAM safely' is the textbook permissions boundary question. It is the only feature that caps what a principal can create.

An engineer reports that an IAM role attached to an EC2 instance cannot write to an S3 bucket. The role has a policy allowing s3:PutObject on that bucket, and the bucket policy also allows the role.

The account belongs to an organisational unit that recently had a new service control policy applied. Other instances in a different OU write to the same bucket without any problem.

What is the MOST likely cause?

- A The identity policy and the bucket policy conflict, so neither takes effect
- B The SCP does not allow s3:PutObject, so the action is denied before identity policies apply
- C IAM roles cannot be used to write to S3 buckets that have a bucket policy
- D The role's temporary credentials have expired and need manual rotation

◆ PAUSE AND DECIDE

What is the MOST likely cause?

- A

 Policies conflict, both void
Not how evaluation works. Two allows do not cancel out; only an explicit deny blocks.
- C

 Roles cannot write to such buckets
Simply untrue. Invented restrictions are common distractors, and are always wrong.
- B

 SCP blocks the action
Two planted clues: a new SCP on this OU, and identical instances in a different OU working fine.
- D

 Credentials expired
The instance profile refreshes credentials automatically. Manual rotation of role credentials is not a thing.

THE SIGNAL

When permissions look correct but fail, look above the account: SCPs, then explicit denies.

A company with 3,000 employees uses Microsoft Active Directory on premises. It is expanding from two AWS accounts to around twenty-five.

Staff currently have separate IAM users in each account. The identity team is spending most of its time on joiners and leavers, and an internal audit found nine active IAM users belonging to people who had left the company.

Which solution addresses this with the LEAST ongoing operational overhead?

- | | |
|--|---|
| A Write a Lambda function that reconciles IAM users against Active Directory nightly | B Configure IAM Identity Center with Active Directory as the identity source |
| C Create one central account holding IAM users, and cross-account roles in the others | D Enforce a password policy and ninety-day key rotation across all accounts |

◆ PAUSE AND DECIDE

Which solution addresses this with the LEAST ongoing operational overhead?

- A

 Custom Lambda reconciliation
Builds and maintains bespoke identity plumbing to replicate a managed feature. Custom code is rarely the LEAST-overhead answer.
- B

 IAM Identity Center with AD
Leavers lose AWS access the moment the AD account is disabled, and there are no per-account users left to drift.
- C

 Hub account with cross-account roles
A real and reasonable pattern that removes duplicate users, but still leaves 3,000 IAM users to provision and deprovision by hand.
- D

 Password policy and rotation
Hygiene, not lifecycle. A rotated password on a departed employee's account is still an active account.

THE SIGNAL

Existing corporate directory plus multiple accounts plus LEAST overhead. That is IAM Identity Center.

Module 1 takeaways

- ◆ **Long-lived key in code or on an instance?** The answer is a role. Every time.
- ◆ **Explicit deny always wins.** SCPs are checked before identity policies and never grant.
- ◆ **'Cannot be overridden by account admins'** means service control policy.
- ◆ **'Delegate IAM safely'** means permissions boundary.
- ◆ **Corporate directory plus many accounts** means IAM Identity Center.

ON THE EXAM

When two options both work in domain one, choose the narrower permission for the shorter time.